

Security Assessment

Vulnerability & Penetration Testing Report

Report ID	0eeb4828	Generated	May 24, 2026
Target	https://octane.stpi.in/	Classification	CONFIDENTIAL

CONFIDENTIAL • AUTHORIZED USE ONLY

Executive Summary

The vulnerability assessment of <https://octane.stpi.in/> has identified CRITICAL security exposures requiring immediate remediation. 0 critical and 5 high severity issues present a substantial risk to data confidentiality, system integrity, and service availability. Exploitation of the identified critical vulnerabilities may result in full system compromise or exfiltration of sensitive data. Immediate action is strongly recommended.

Detailed Findings

#001 Missing Content-Security-Policy HeaderHIGH CVSS 7.5 [CONFIRMED]

OWASP: A05 — Security Misconfiguration

The response from <https://octane.stpi.in/> is missing the 'content-security-policy' security header. This reduces browser-level protection against common attack classes.

Remediation: Add CSP: Content-Security-Policy: default-src 'self'; script-src 'self'

#002 Missing HSTS HeaderHIGH CVSS 7.5 [SAST]

OWASP: A05 — Security Misconfiguration

HTTP Strict Transport Security not set — SSL stripping attacks possible.

Remediation: Add: Strict-Transport-Security: max-age=31536000; includeSubDomains

#003 Sensitive Endpoint Accessible Without Auth: /adminHIGH CVSS 8.1 [DAST]

OWASP: A01 — Broken Access Control

The path '/admin' returned HTTP 200 with sensitive content without authentication. Keywords found: ['admin']. An unauthenticated attacker can access this resource directly.

Remediation: Require authentication for all administrative paths. Implement server-side role-based access control. Never rely on obscurity — check permissions on every request.

#004 Sensitive Endpoint Accessible Without Auth: /admin/HIGH CVSS 8.1 [DAST]

OWASP: A01 — Broken Access Control

The path '/admin/' returned HTTP 200 with sensitive content without authentication. Keywords found: ['admin']. An unauthenticated attacker can access this resource directly.

Remediation: Require authentication for all administrative paths. Implement server-side role-based access control. Never rely on obscurity — check permissions on every request.

#005 Sensitive Data Exposed in Response: possible credit card number**HIGH CVSS 7.5 [DAST]**

OWASP: A02 — Cryptographic Failures

The response at 'https://octane.stpi.in/' contains possible credit card number. Sensitive values must never be returned in API responses unnecessarily. This data can be captured by a MITM or I

Remediation: Remove sensitive fields from API responses. Apply field-level encryption for PII. Never return credentials, keys, or tokens in responses.

#006 Missing HSTS Header**MEDIUM CVSS 5.9 [DAST]**

OWASP: A02 — Cryptographic Failures

The HTTPS endpoint 'https://octane.stpi.in/' does not send the Strict-Transport-Security header. Without HSTS, browsers may connect over HTTP on subsequent visits, enabling SSL-stripping attac

Remediation: Add: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

#007 Missing X-Content-Type-Options Header**MEDIUM CVSS 5.3 [CONFIRMED]**

OWASP: A05 — Security Misconfiguration

The response from https://octane.stpi.in/ is missing the 'x-content-type-options' security header. This reduces browser-level protection against common attack classes.

Remediation: Add: X-Content-Type-Options: nosniff

#008 Missing X-Frame-Options Header**MEDIUM CVSS 5.3 [CONFIRMED]**

OWASP: A05 — Security Misconfiguration

The response from https://octane.stpi.in/ is missing the 'x-frame-options' security header. This reduces browser-level protection against common attack classes.

Remediation: Add: X-Frame-Options: DENY (or use CSP frame-ancestors)

#009 Cookie Missing HttpOnly Flag**MEDIUM CVSS 6.5 [SAST]**

OWASP: A07 — Security Misconfiguration

Session cookie accessible to JavaScript — theft via XSS possible.

Remediation: Add HttpOnly flag to all session cookies.

#010 Dangerous HTTP Methods Enabled: TRACE**MEDIUM CVSS 6.5**
[DAST]

OWASP: A01 — Broken Access Control

OPTIONS request to 'https://octane.stpi.in/' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow

Remediation: Disable TRACE globally in web server config. Restrict PUT/DELETE to authenticated and authorized endpoints only. Return 405 for all unexpected HTTP methods.

#011 Mixed Content — HTTP Resources on HTTPS Page**MEDIUM CVSS 5.9**
[DAST]

OWASP: A02 — Cryptographic Failures

The HTTPS page at 'https://octane.stpi.in/' loads 3 resource(s) over plain HTTP. Mixed content allows attackers to intercept or modify these resources, potentially injecting malicious scripts

Remediation: Update all resource URLs to use HTTPS. Add Content-Security-Policy: upgrade-insecure-requests or block-all-mixed-content directives.

#012 Session Cookie Missing HttpOnly Flag**MEDIUM CVSS 6.5**
[DAST]

OWASP: A07 — Identification and Authentication Failures

Set-Cookie header at https://octane.stpi.in/ is missing the 'httponly' attribute.

Remediation: Add HttpOnly to all session cookies.

#013 Subresource Integrity (SRI) Attribute Missing**MEDIUM CVSS 5.5**
[DAST]

OWASP: A08 — Software and Data Integrity Failures

Found 4 external script/link tag(s) at https://octane.stpi.in/ without an integrity attribute. Without SRI, if the external CDN is compromised, malicious code could be injected into your pages.

Remediation: Add integrity and crossorigin attributes to all external scripts/links: . Generate hashes at: https://www

#014 Missing Referrer-Policy**LOW CVSS 2.7**
[CONFIRMED]

OWASP: A05 — Security Misconfiguration

The response from https://octane.stpi.in/ is missing the 'referrer-policy' security header. This reduces browser-level protection against common attack classes.

Remediation: Add: Referrer-Policy: strict-origin-when-cross-origin

#015 Missing Permissions-Policy**LOW CVSS 2.7**
[CONFIRMED]

OWASP: A05 — Security Misconfiguration

The response from <https://octane.stpi.in/> is missing the 'permissions-policy' security header. This reduces browser-level protection against common attack classes.

Remediation: Add Permissions-Policy to disable unneeded browser APIs

#016 Server Technology Version Disclosed: Microsoft-IIS/8.5**LOW CVSS 2.7 [DAST]**

OWASP: A05 — Security Misconfiguration

The 'server' header reveals the server technology and version: 'Microsoft-IIS/8.5'. Attackers can use this to target known CVEs for that specific version.

Remediation: Remove or generalise the 'server' header in server configuration.

#017 Server Version Disclosure**LOW CVSS 2.7 [SAST]**

OWASP: A05 — Security Misconfiguration

Server header exposes version: Microsoft-IIS/8.5

Remediation: Remove or obfuscate the Server header.

#018 Session Cookie Missing SameSite**LOW CVSS 4.2 [DAST]**

OWASP: A07 — Identification and Authentication Failures

Set-Cookie header at <https://octane.stpi.in/> is missing the 'samesite' attribute.

Remediation: Add SameSite=Strict or Lax to session cookies.

#019 Password Field Allows Autocomplete**LOW CVSS 4.2 [DAST]**

OWASP: A07 — Identification and Authentication Failures

A password input at <https://octane.stpi.in/stylesheets/style.css> does not have autocomplete='off'. Browsers may cache credentials and expose them to other users on shared devices.

Remediation: Add autocomplete='off' or autocomplete='new-password' to all password fields.